

TP - Hardening Linux lvl 3

L'objectif de ce TP est de construire une version améliorée de la machine issue du TP "Hardening Linux 2" en proposant les mesures de sécurité complémentaires suivantes :

1) Service SSH

Le service doit être configuré pour répondre aux besoins suivants :

- Le port d'écoute doit être modifié au profit du port 22222
- Le service ne doit écouter que sur le stack IPv4
- Le service ne doit proposer que le SSH v2
- Le service doit permettre exclusivement l'authentification publickey,keyboard-interactive (aucune authentification par mot de passe)
- L'authentification doit se couper dès le premier essai échoué ou après 30 secondes d'attente
- Le service ne doit pas permettre le forwarding TCP ou X11
- L'authentification basée sur l'hôte doit être désactivée (Il faut également s'assurer que les fichiers rhosts sont ignorés)
- Le service ne doit pas autoriser les variables d'environnement de l'utilisateur
- En cas d'inactivité, l'utilisateur doit être déconnecté au bout de 1m30
- Le serveur ne doit pas proposer de KeepAlive
- Les éléments de configuration cryptographiques du service doivent suivre les standards de sécurité actuels

2) Service HTTP

La machine a pour objectif d'héberger un service http (Apache Httpd). Celui-ci doit être installé en suivant les prérequis suivants :

- Le service ne doit écouter que sur le stack IPv4 sur les ports 8080 et 443
- Le service apache httpd doit être capable d'exécuter du code PHP

Un fichier index.php contenant le code suivant doit être placé à la racine du répertoire de publication

```
<?php
    printf("<h1>Hello World !</h1>");
?>
```

- Le répertoire de publication du service doit être /data/http/www

Le répertoire /data/http doit appartenir à l'utilisateur initiant le service.

- Le serveur doit être configuré pour fonctionner en HTTPS

Le port 80 (HTTP) doit rediriger automatiquement vers le port 443 (HTTPS). Cette redirection doit être applicative.

La configuration des éléments de chiffrement doit suivre les standards de sécurité actuels.

- Le service ne doit fournir aucune information de version dans l'entête de ses réponses

Pare-feu

Le système Iptables doit être mis en place pour répondre aux besoins suivants :

- Le pare-feu doit être lancé au démarrage de la machine sous la forme d'un service
- Le pare-feu doit être limité en entrée

```
> Tous les nouveaux paquets ICMP entrant doivent être jetés
> Les paquets entrants en TCP/80 sont autorisés
> Les paquets entrants en TCP/22 sont autorisés depuis la machine
d'administration uniquement
> Le reste des nouveaux paquets entrants doivent être jetés
> Les paquets entrants connus doivent être autorisés (réponses)
```

- Le pare-feu doit être limité en sortie

```
> Les paquets ICMP en sortie (ICMP Echo/Request) sont autorisés
> Tous les nouveaux paquets ICMP sortants doivent être jetés
> Les résolutions DNS sortantes doivent être autorisées
> Les flux HTTPS (TCP/443) en sortie sont autorisés
> Les paquets sortant connus doivent être autorisés (réponses)
```

- Le pare-feu doit être configuré pour rediriger le port 80 vers le port 8080 local
- La politique par défaut du pare-feu doit être de jeter tous les paquets
- Le pare-feu doit permettre la journalisation de l'intégralité des flux (autorisés et jetés) avec un entête différent ([IPTABLES-ACCEPT] ou [IPTABLES-DROP])

Notes

A la fin de la configuration, il ne devrait y avoir que 3 ports en LISTEN sur 0.0.0.0 sur la machine et uniquement en IPv4 `netstat -lntuop`

ANSSI : Best Practices pour TLS <https://www.ssi.gouv.fr/guide/recommandations-de-securite-relatives-a-tls/>

Générateur de config SSL Mozilla : <https://ssl-config.mozilla.org/>